

Prompt Injection in AI Browsers

What fails, what works, and a 90-day plan to secure your AI-enabled workforce

by RockCyber





Why This Matters Now

Elevated Privileges

AI browsers operate with full user credentials across every connected application and service

Hidden Manipulation

Malicious content embedded in pages can silently redirect agent behavior without user awareness

Security Blind Spot

Traditional same-origin protections fail to constrain AI agents acting on behalf of users

Prompt Injection in One Sentence

Text becomes executable instructions for the AI agent, allowing attackers to hide malicious commands in pages, documents, or images that trigger data exfiltration and unauthorized actions.

Invisible Text

White text on white backgrounds or CSS-hidden content steers agent decisions

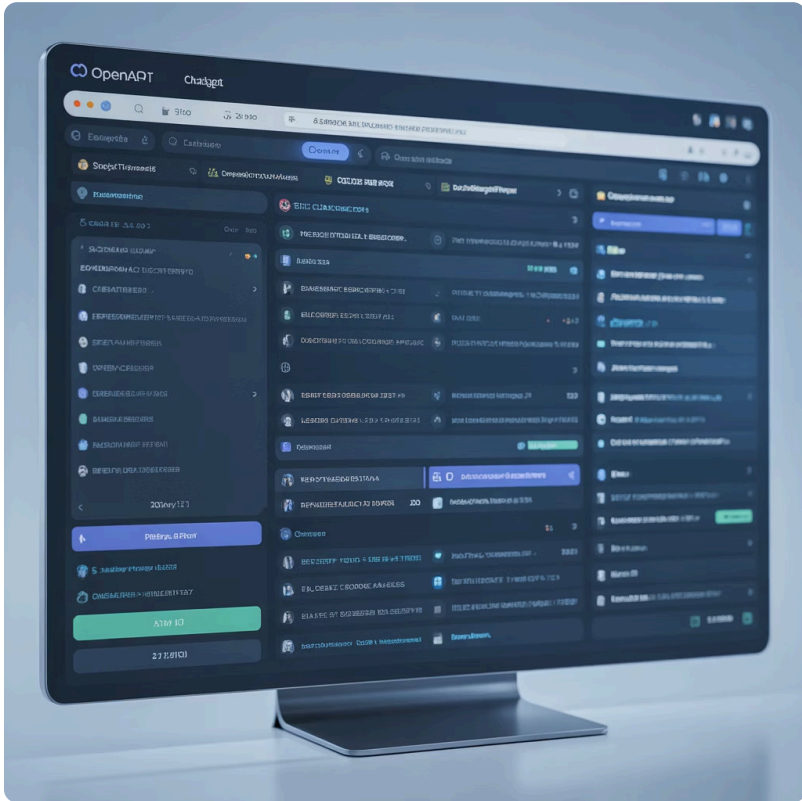
Hidden HTML

Markup elements invisible to users but parsed by the agent's context window

OCR Attacks

Instructions embedded in screenshots and images that agents read and execute

Case Study: OpenAI ChatGPT Atlas



Initial Vulnerability

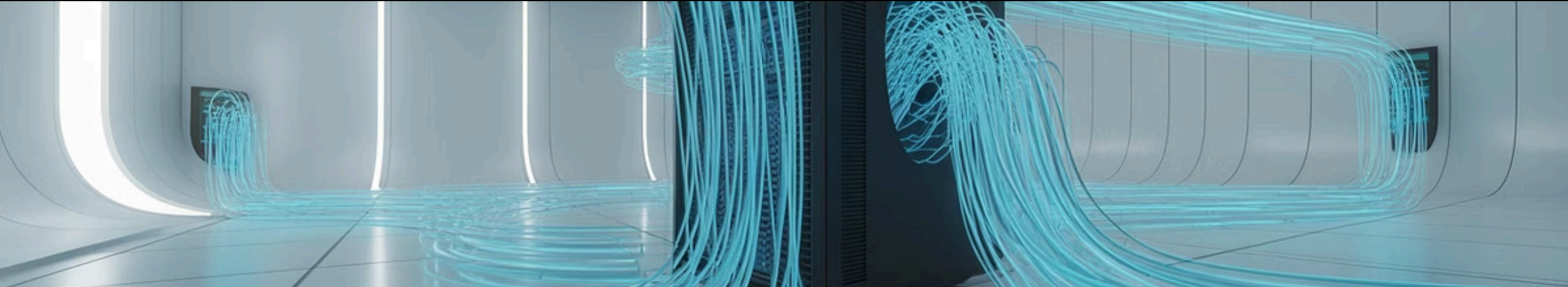
Launch testing revealed significant susceptibility to indirect prompt injection attacks embedded in web content.

Vendor Response

OpenAI deployed logged-out browsing mode and watch mode to limit agent permissions and reduce attack surface.

Key Lesson

Defense-in-depth mitigations help reduce risk, but fundamental exposure persists in the architecture.



Case Study: Perplexity Comet

1

Attack Vector

Invisible or low-contrast text triggered multi-step agent actions across connected services

2

Live Demonstration

Researchers executed complete chain: read email OTP, authenticate, and exfiltrate sensitive data

3

Arms Race

Vendor patches landed quickly, but new bypass techniques emerged within weeks



Case Study: CometJacking

Single-Click Hijack

A single click on a specially crafted URL completely hijacks the AI agent, granting attackers control over multi-service data access.

01

Encoded Payload

Malicious instructions embedded in URL parameters bypass visual inspection

02

Agent Compromise

Browser agent parses and executes commands across all connected accounts

03

Data Exfiltration

Stolen information transmitted via HTTP POST requests or public forum replies

Case Study: Fellou Browser

Architecture Flaw

Navigation logic sent entire page content to the LLM without proper instruction-data separation or sandboxing.

Exploitation

Visible text on attacker-controlled pages could completely override legitimate user goals and commands.

Broader Pattern

Smaller vendors often share identical systemic vulnerabilities, magnifying enterprise exposure across tool sprawl.



Why Classic Web Security Fails

Control	Traditional Scope	Agent Reality
Same-Origin Policy	Isolates script execution by origin	Agents act cross-site with full user tokens
CSRF Tokens	Validates request authenticity	Agent carries valid session state everywhere
Content Security Policy	Restricts resource loading	Agent reads all content including hidden text
Input Validation	Sanitizes form submissions	OCR and encodings create unbounded input surface

AI agents operate in a fundamentally different threat model where traditional browser security boundaries provide minimal protection.

What Works Today



Mode Isolation

Separate read-only and action modes. Default to logged-out browsing for maximum isolation.



Least Privilege Tools

Scope agent tool access to minimum required permissions per task context.



User Confirmation

Require explicit approval for sensitive actions like email sends or financial transactions.



Instruction Firewall

Deploy prompt filtering and DOM sanitization to detect and block injection attempts.



Constrain OCR

Limit optical character recognition and block suspicious text encodings in images.



Flow Monitoring

Track prompt sequences and tool invocation patterns for anomaly detection.



30-Day Action Plan



Immediate Restrictions

Ban AI agent use on all sensitive applications including email, finance, and HR systems



Asset Discovery

Complete inventory of all AI browsers, extensions, and agent tools deployed across the organization



Default Configuration

Enable logged-out mode by default on all approved AI browser installations



User Awareness

Train security and IT staff to recognize telltale symptoms of prompt injection attacks

☐ **Success Metric:** Zero AI-agent traffic to protected applications and services



60 and 90-Day Roadmap

1

60 Days: Detection

- Deploy AI-aware monitoring with behavior baselines
- Implement identity-aware browser isolation
- Draft Sensitive Action Confirmation policy
- Define Agent Tool Scope framework
- Establish Third-Party Content controls

2

90 Days: Validation

- Execute red-team exercises with canary prompts
- Integrate prompt injection tests into CI/CD
- Harden production configurations
- Publish SOC runbooks and response playbooks
- Conduct executive risk briefing

About RockCyber

RockCyber helps enterprises operationalize secure AI adoption through comprehensive governance, risk assessment, and control architectures tailored to your specific environment.

Services

- Fractional CISO and CAIO
- AI risk assessment and threat modeling
- Security policy design and implementation
- Secure agent architecture consulting
- Red-team exercises and penetration testing
- Compliance mappings and audit support

Visit Website

Connect on LinkedIn

Resources

Blog: rockcybermusings.com

Follow for weekly AI security insights